

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-07-08 · Model: `0.5·CVE + 0.3·exposure + 0.2·criticality`

Summary

Metric	Count
Dependencies scored	24 (23 resolved + 1 unresolved typosquat)
CRITICAL	1
HIGH	4
MEDIUM	3
LOW	16

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` (missing the "er" in `fasterxml`) does not exist on Maven Central and only resolves through the blocked `internal-untrusted-mirror` HTTP repository. It is floored at CRITICAL regardless of the mechanical weighted score — remove it entirely rather than remediate a version.

HIGH — Log4Shell still in the tree. `log4j-core:2.14.1` carries CVE-2021-44228 (CVSS 10.0) and CVE-2021-45046 (CVSS 9.0). Any dependency with a CRITICAL CVE is floored at band HIGH per policy.

Scanner data-source note. OWASP Dependency-Check's local NVD mirror (warm cache, 230k+ vulnerability rows) has no CPE entries at all for `apache:log4j`, `fasterxml:jackson-databind`, or `google:guava` — a partial/limited mirror, not a clean bill of health. Every CVE below was independently confirmed (and version-range verified) directly against the live NVD API and is tagged `cvss_source: nvd` in `depscan-risk-report.json`.

Ranked remediation backlog

#	Coordinate	Version	Band	Risk	Top CVE / issue	Fix
1	<code>com.fastxml.jackson.core:jackson-databind</code>	2.9.8	CRITICAL	9.5*	Typosquat — remove	remove dependency
2	<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.17.1
3	<code>mysql:mysql-connector-java</code>	8.0.30	HIGH	7.2	CVE-2023-22102 (8.3)	8.2.0+ (verify Oracle CPU)
4	<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	HIGH	6.8	CVE-2020-36518 (7.5)	2.12.6.1 (then keep going — many more)

						CVEs exist past 2.13.x)
5	com.google.protobuf:protobuf-java	3.19.4	HIGH	6.7	CVE-2022-3509 (7.5)	3.25.5
6	commons-io:commons-io	2.4	MEDIUM	5.2	CVE-2021-29425 (4.8)	2.14.0
7	org.apache.commons:commons-lang3	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0
8	com.google.guava:guava	24.1.1-jre	MEDIUM	4.2	CVE-2020-8908 (3.3)	32.0.0
9	org.apache.logging.log4j:log4j-api	2.14.1	LOW	2.8	none (ships w/ log4j-core)	2.17.1 (lockstep)
10	com.fasterxml.jackson.core:jackson-core	2.9.8	LOW	2.2	none	lockstep w/ jackson-databind
11	com.fasterxml.jackson.core:jackson-annotations	2.9.0	LOW	2.2	none	lockstep w/ jackson-databind
12–16	guava transitives (jsr305, checker-qual, error-prone-annotations, j2objc-annotations, animal-sniffer-annotations)	various	LOW	1.9	none	ride along with guava bump
17–24	junit-jupiter + test-scope transitives	5.10.2 / 1.10.2 / 1.3.0 / 1.1.2	LOW	1.1–1.7	none	6.1.1 (test-scope, low urgency)

*Row 1's score is a manual override (supply-chain risk), not the CVE-weighted formula — see callout above.

Component scores (highest-risk items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
log4j-core	10.0	8.0	2.0	7.8
mysql-connector-java	8.8	8.0	2.0	7.2
jackson-databind	8.0	8.0	2.0	6.8
protobuf-java	9.0	6.0	2.0	6.7
commons-io	5.3	7.0	2.0	5.2
commons-lang3	5.3	7.0	2.0	5.2
guava	3.3	7.0	2.0	4.2

Priority recommendations

- P0** — Remove the typosquatted `com.fastxml.jackson.core:jackson-databind` dependency block and the `internal-untrusted-mirror` repository entry (supply-chain).
- P0** — Upgrade `log4j-core` / `log4j-api` 2.14.1 → 2.17.1 in lockstep (Log4Shell family, CRITICAL, actively exploited in the wild historically).
- P1** — Upgrade `mysql-connector-java` 8.0.30 → 8.2.0+ (verify against the latest Oracle CPU) and swap off the GPL-2.0-licensed artifact for the Apache-2.0 MySQL Connector/J (`com.mysql:mysql-connector-j`) to also clear the license violation.
- P1** — Upgrade `jackson-databind` well past 2.13.x (the 2.9.x line has a long additional CVE history beyond the two verified here); bump `jackson-core` / `jackson-annotations` in lockstep.
- P1** — Upgrade `protobuf-java` (transitive via `mysql-connector-java`) to 3.25.5+; verify the fix flows through once `mysql-connector-java` is upgraded, else pin explicitly.

6. **P2** — Routine bumps: `commons-io` → 2.14.0+, `commons-lang3` → 3.18.0+, `guava` → 32.0.0+ (major — review for API breakage).
7. **P3** — `junit-jupiter` and friends are test-scope only; bump opportunistically, not urgent.

Machine-readable source: `depscan-risk-report.json` (24 ranked entries). Findings source: `depscan-report.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 2 (Risk Scoring Agent).